ANNEXE A

Version : 1.0

Classification : Interne

Statut : Approuvée

Auteur : Consultant Cybersécurité

Client : BioMarket

Approbateur : Direction Générale — Antoine Verger

Historique des versions

Version	Date	Auteur	Description
0.1	01/02/2026	Consultant cybersécurité	Création du document
0.9	15/02/2026	DSI	Relecture technique
1.0	28/02/2026	Direction Générale	Validation finale

Diffusion

Destinataire	Diffusion
Direction Générale	Oui
DSI	Oui
Responsable RH	Oui
Consultant cybersécurité	Oui
Équipe informatique	Oui
Iron4Software (extrait)	Selon les besoins

Confidentialité

Ce document est destiné exclusivement aux personnes autorisées par BioMarket. Il contient des informations relatives à l'organisation du projet de certification du SMSI et ne peut être diffusé sans l'accord de la Direction.

Table des matières

ANNEXE A 1

Historique des versions 1

Diffusion 1

Confidentialité 1

Table des matières 2

1. Présentation de BioMarket 5

1.1 Présentation générale de l'entreprise 5

1.2 Valeurs et stratégie de l'entreprise 5

1.3 Projet de transformation numérique 5

1.4 État actuel du système d'information 6

1.5 Conclusion 6

2 Analyse du contexte de l'entreprise 8

2.1 Contexte interne 8

2.2 Contexte externe 8

2.3 Analyse PESTEL 8

2.3 Analyse SWOT 9

2.4 Enjeux métiers 10

2.5 Conclusion 10

3 Identification des parties prenantes 11

3.1 Définition 11

3.2 Identification des parties prenantes 11

3.3 Analyse des attentes 12

3.4 Matrice Pouvoir / Intérêt 13

3.5 Conclusion 13

4 Mise en place d'une veille cybersécurité 14
4.1 Contexte 14
4.2 Objectifs de la veille 14
4.3 Sources retenues 14
4.4 Procédure de veille 15
4.5 Tableau de suivi de veille 16
4.6 Outils de veille 16
4.7 Conclusion 16
5 Analyse OSINT 17
5.1 Objectif 17
5.2 Méthodologie 17
5.3 Outils utilisés 17
5.4 État des lieux de l'exposition numérique 17
5.5 Analyse des résultats 18
5.6 Recommandations 18
5.7 Conclusion 19
6 Identifier les besoins spécifiques de BioMarket en matière de sécurité 20
6.1 Objectif 20
6.2 Contexte de BioMarket 20
6.3 Les besoins de sécurité selon le modèle DICP 20
6.4 Identification des besoins spécifiques de BioMarket 22
6.5 Les mécanismes de sécurité associés 22
6.6 Conclusion 23
7 Cartographie de l'architecture technique actuelle 24
7.1 Objectif 24
7.2 Périmètre de la cartographie 24

7.3 Description générale de l'architecture 24

7.4 Connexions externes et accès distants 26

7.5 Plateforme e-commerce et services Cloud 26

7.6 Description des principaux flux 27

7.7 Inventaire des principaux composants 28

7.8 Analyse de l'architecture actuelle 29

7.9 Conclusion 29

1. Présentation de BioMarket

1.1 Présentation générale de l'entreprise

BioMarket est une enseigne spécialisée dans la distribution de produits issus de l'agriculture biologique. Fondée il y a plus de vingt ans à Tourcoing par Antoine Verger, l'entreprise s'est progressivement imposée comme un acteur régional majeur en développant un réseau de plus de cinquante points de vente répartis entre le Nord de la France et la Belgique.

L'entreprise s'appuie sur un modèle économique reposant sur la commercialisation de produits alimentaires biologiques, locaux et responsables. Son activité s'inscrit dans une démarche de développement durable visant à promouvoir une consommation plus respectueuse de l'environnement et de la santé des consommateurs.

Face à l'évolution des habitudes de consommation, BioMarket souhaite désormais compléter son réseau de magasins physiques par une plateforme de commerce électronique. Cette évolution stratégique doit permettre d'élargir sa clientèle, d'améliorer l'expérience utilisateur et de renforcer sa compétitivité face aux autres enseignes spécialisées dans le secteur des produits biologiques.

1.2 Valeurs et stratégie de l'entreprise

Le développement de BioMarket repose sur quatre valeurs fondamentales :

- la qualité des produits proposés ;
- le respect de l'environnement ;
- le bien-être des consommateurs ;
- la transparence dans les relations avec les clients et les partenaires.

Ces valeurs dépassent le simple cadre commercial. Elles influencent directement les exigences de sécurité du système d'information.

La transparence impose notamment une gestion rigoureuse des données personnelles, tandis que la qualité implique de garantir l'intégrité des informations relatives aux commandes, aux stocks et aux fournisseurs. De même, la confiance accordée par les clients repose sur la capacité de l'entreprise à assurer la confidentialité des données collectées ainsi que la disponibilité des services numériques.

Ainsi, la cybersécurité constitue un élément essentiel de la stratégie globale de BioMarket puisqu'elle contribue directement à préserver l'image de marque et la confiance des consommateurs.

1.3 Projet de transformation numérique

Afin de répondre aux nouveaux usages des consommateurs, BioMarket a décidé de développer une plateforme e-commerce comparable à celles de ses principaux concurrents.

La plateforme e-commerce constitue un nouveau composant du système d'information de BioMarket. Hébergée sur une infrastructure PaaS et développée par Iron4Software, elle est destinée à être exploitée pour le compte de BioMarket. À ce titre, elle est intégrée au périmètre du système d'information et du futur SMSI, bien que son développement soit toujours en cours.

Ce projet représente un changement majeur pour l'entreprise. Il implique la création de nouveaux services numériques accessibles depuis Internet, le traitement de données personnelles sensibles et l'interconnexion avec différents partenaires et prestataires.

Cette ouverture du système d'information augmente considérablement la surface d'exposition aux cybermenaces. Les principaux risques concernent notamment :

- le vol de données personnelles des clients ;
- les attaques par rançongiciel ;
- les compromissions de comptes privilégiés ;
- les interruptions de service de la plateforme e-commerce ;
- les attaques visant les applications web.

La cybersécurité ne doit donc pas être considérée comme une contrainte technique mais comme un levier permettant de sécuriser le développement de cette nouvelle activité. C'est pourquoi BioMarket a fait le choix d'intégrer la sécurité dès la conception du projet.

1.4 État actuel du système d'information

L'analyse de l'existant montre que BioMarket dispose déjà de plusieurs mesures de sécurité pertinentes.

Parmi les dispositifs mis en œuvre figurent :

- un pare-feu Fortinet filtrant les communications entrantes ;
- une politique de mots de passe renforcée ;
- l'utilisation d'une authentification multifacteur (MFA) pour les comptes à privilèges ;
- une segmentation du réseau à l'aide de VLAN ;
- un accès distant sécurisé par VPN avec authentification par certificat ;
- un annuaire Active Directory centralisé ;
- un stockage hybride des données entre les infrastructures locales et le cloud.

Toutefois, plusieurs faiblesses importantes ont également été identifiées :

- des mots de passe sont conservés sur des supports papier à proximité des postes de travail ;
- certains postes restent déverrouillés en l'absence de leur utilisateur ;
- des comptes utilisateurs demeurent actifs après le départ de collaborateurs ;
- aucune revue périodique des droits d'accès n'est réalisée ;
- certaines données sensibles sont stockées en clair sur les serveurs locaux ;
- l'entreprise ne dispose pas encore d'un Délégué à la Protection des Données (DPO) ni d'un audit interne formalisé.

Ces constats mettent en évidence un écart entre les mesures techniques déjà déployées et la maturité globale de la gouvernance de la cybersécurité.

1.5 Conclusion

L'étude de BioMarket montre que l'entreprise possède des bases techniques solides pour protéger son système d'information. Les solutions déjà déployées démontrent une volonté d'investir dans la sécurité des infrastructures.

En revanche, les principaux axes d'amélioration concernent désormais la gouvernance de la sécurité. Plusieurs processus essentiels ne sont pas encore formalisés, notamment la gestion des accès, la revue des habilitations, la gestion des incidents, la conformité RGPD ou encore la sensibilisation des collaborateurs.

Dans le contexte du lancement d'une plateforme e-commerce, ces faiblesses représentent un risque significatif. Une cyberattaque pourrait entraîner une indisponibilité des services, une fuite de données personnelles ou une dégradation de l'image de marque de BioMarket.

Il apparaît donc nécessaire de mettre en place une démarche globale de management de la sécurité de l'information fondée sur la norme ISO 27001. Cette démarche devra permettre d'organiser la gouvernance de la cybersécurité, de formaliser les processus de sécurité et d'assurer une amélioration continue des mesures de protection mises en œuvre.

---

2 Analyse du contexte de l'entreprise

2.1 Contexte interne

BioMarket est une entreprise en pleine évolution. Son réseau de magasins physiques constitue aujourd'hui son principal canal de distribution, mais la mise en œuvre d'une plateforme e-commerce marque une étape importante dans sa transformation numérique.

Cette évolution entraîne une augmentation des échanges numériques, du volume de données traitées et du nombre d'utilisateurs ayant accès au système d'information. Les données manipulées comprennent notamment des informations relatives aux clients, aux commandes, aux paiements, aux fournisseurs et aux salariés. Ces informations représentent des actifs stratégiques dont la protection est essentielle pour assurer la continuité des activités de l'entreprise.

L'analyse de l'infrastructure existante montre que BioMarket dispose déjà de plusieurs mécanismes de sécurité : un pare-feu Fortinet, un annuaire Active Directory, une authentification multifacteur pour certains comptes, un accès distant sécurisé par VPN et une segmentation du réseau à l'aide de VLAN. Ces mesures constituent une base technique solide, mais elles doivent être complétées par une gouvernance de la sécurité plus structurée.

2.2 Contexte externe

L'environnement de BioMarket est marqué par une forte concurrence dans le secteur de la distribution alimentaire et par une évolution constante des attentes des consommateurs.

Le développement du commerce électronique expose désormais l'entreprise à des menaces qui étaient auparavant limitées. Les cybercriminels ciblent régulièrement les plateformes e-commerce afin de voler des données personnelles, détourner des moyens de paiement ou interrompre les services par des attaques de type rançongiciel ou déni de service.

En parallèle, BioMarket doit respecter plusieurs exigences réglementaires, notamment le RGPD concernant la protection des données personnelles, ainsi que les bonnes pratiques de cybersécurité recommandées par l'ANSSI. La maîtrise de ces exigences est indispensable pour préserver la confiance des clients et limiter les risques juridiques.

2.3 Analyse PESTEL

Facteur	**Analyse**
Politique	Les politiques nationales et européennes renforcent les exigences en matière de cybersécurité. Les recommandations de l'ANSSI et les directives européennes incitent les entreprises à améliorer la protection de leurs systèmes d'information.
Économique	Le développement du e-commerce représente une opportunité de croissance, mais une cyberattaque pourrait entraîner une perte financière importante, des coûts de remédiation et une interruption de l'activité.

Facteur	Analyse
Socioculturel	Les consommateurs sont de plus en plus attentifs à la protection de leurs données personnelles. Une fuite de données pourrait dégrader durablement la confiance envers BioMarket.
Technologique	Le recours au cloud, aux solutions VPN, à l'authentification multifacteur et aux plateformes e-commerce augmente la dépendance aux technologies numériques, tout en élargissant la surface d'attaque.
Environnemental	La stratégie de BioMarket repose sur le développement durable. La continuité des services numériques participe également à une gestion responsable des ressources et limite les impacts liés aux interruptions d'activité.
Légal	BioMarket doit respecter le RGPD pour les données personnelles, ainsi que les obligations contractuelles vis-à-vis de ses partenaires. La mise en œuvre d'un SMSI inspiré de l'ISO 27001 contribuera à renforcer sa conformité.

2.3 Analyse SWOT

Forces	**Faiblesses**
Présence régionale reconnue	Comptes utilisateurs non révoqués après certains départs
Infrastructure réseau déjà sécurisée (VPN, Fortinet, VLAN)	Gestion des mots de passe insuffisante (Post-it, pratiques utilisateurs)
Utilisation de l'authentification multifacteur pour certains accès	Données sensibles stockées en clair sur certains serveurs
Projet soutenu par la direction	Gouvernance SSI encore peu formalisée
Opportunités	**Menaces**
Développement du e-commerce	Rançongiciels
Fidélisation de nouveaux clients	Vol de données personnelles
Amélioration de l'image de marque	Phishing ciblant les collaborateurs
Modernisation du système d'information	Indisponibilité de la plateforme e-commerce

---

2.4 Enjeux métiers

Les principaux enjeux métiers identifiés sont :

- assurer la disponibilité de la plateforme e-commerce afin de garantir la continuité des ventes ;
- protéger les données personnelles des clients conformément au RGPD ;
- préserver la confiance des consommateurs et l'image de marque de BioMarket ;
- garantir la fiabilité des informations relatives aux commandes, aux stocks et aux paiements ;
- accompagner la croissance de l'entreprise sans compromettre la sécurité du système d'information.

2.5 Conclusion

L'analyse du contexte montre que BioMarket dispose d'une base technique satisfaisante pour accompagner son projet de transformation numérique. Toutefois, la cybersécurité ne peut pas reposer uniquement sur des équipements techniques.

Les principales difficultés identifiées concernent la gouvernance de la sécurité, la gestion des identités, la protection des données sensibles et la formalisation des processus. Dans le cadre du futur SMSI, ces éléments devront être traités en priorité afin de réduire les risques pesant sur les actifs stratégiques de l'entreprise.

L'analyse du contexte constitue ainsi le point de départ de la démarche de cybersécurité. Elle permettra, dans les chapitres suivants, d'identifier les parties prenantes, d'analyser les risques et de définir les mesures de sécurité les plus adaptées.

---

3 Identification des parties prenantes

3.1 Définition

Dans le cadre du projet de sécurisation de la future plateforme e-commerce, plusieurs acteurs interviennent à différents niveaux. Chaque partie prenante possède des responsabilités spécifiques et des attentes particulières en matière de sécurité de l'information.

L'identification de ces acteurs constitue une étape essentielle de la gouvernance de la cybersécurité. Elle permet de définir les responsabilités, d'identifier les besoins de sécurité et de limiter les risques liés aux accès ou aux interactions entre les différents intervenants.

3.2 Identification des parties prenantes

Partie prenante interne	Responsable	Rôle	Attentes	Niveau d'influence	Niveau de criticité
Direction Responsable générale	Antoine Verger	Définit la stratégie, valide le budget et les orientations	Réduction des risques, rentabilité, image de marque	Très élevé	Très élevé
Direction des Systèmes d'Information (DSI)	Mme Berthion	Pilote le SI et la sécurité	Disponibilité, sécurité, conformité	Très élevé	Très élevé
Service RH	DRH	Création, modification et suppression des comptes Active Directory	Gestion fiable des identités et des habilitations	Élevé	Élevé
Équipe informatique		Administration et maintenance des infrastructures	Outils fiables, procédures claires	Élevé	Élevé
Employés		Utilisateurs quotidiens du SI	Simplicité d'utilisation, accès aux applications	Moyen	Élevé
DPO	A désigner	Supervision de la conformité RGPD	Protection des données personnelles	Élevé	Élevé

Partie prenante externe	Responsable	Rôle	Attentes	Niveau d'influence	Niveau de criticité
Clients	Consommateurs BioMarket	Utilisent la plateforme e-commerce	Confidentialité des données, disponibilité du service	Élevé	Très élevé
Fournisseurs	Ferme des Collines	Approvisionnement et échanges de données	Continuité des échanges	Moyen	Moyen
Fournisseurs	Nature & Bocaux	Approvisionnement et échanges de données	Continuité des échanges	Moyen	Moyen
Partenaire logistique	NordisBio Distribution	Distribution régionale	Continuité des livraisons et accès aux magasins	Moyen	Élevé
Prestataire	Iron4Software	Développement de la plateforme e-commerce	Accès sécurisé aux environnements de développement	Élevé	Très élevé

3.3 Analyse des attentes

Chaque partie prenante poursuit des objectifs différents.

La Direction générale souhaite maîtriser les risques tout en garantissant la réussite du projet de transformation numérique.

La DSI attend une gouvernance claire, des procédures documentées et des mesures de sécurité adaptées aux risques identifiés.

Les collaborateurs souhaitent disposer d'outils simples à utiliser, sans que les mesures de sécurité ne compliquent excessivement leur travail quotidien.

Les clients attendent principalement que leurs données personnelles soient protégées et que la plateforme soit disponible à tout moment.

Enfin, le prestataire Iron4Software doit disposer d'un accès sécurisé aux environnements de développement, tout en respectant les exigences de sécurité définies par BioMarket.

3.4 Matrice Pouvoir / Intérêt

	Faible intérêt	**Fort intérêt**
Pouvoir élevé	Fournisseurs stratégiques	Direction générale, DSI, Iron4Software
Pouvoir faible	Prestataires secondaires	Clients, Employés

Analyse :

- **Direction générale** : forte influence et fort intérêt, elle doit être étroitement associée aux décisions.
- **DSI** : responsable de la mise en œuvre opérationnelle, elle est un acteur clé du projet.
- **Iron4Software** : partenaire stratégique pour le développement de la plateforme ; ses accès devront être strictement contrôlés.
- **Clients** : peu de pouvoir direct sur le projet mais un fort intérêt, car ils sont les premiers concernés par la protection de leurs données.
- **Employés** : leur sensibilisation est essentielle pour réduire le risque humain.

3.5 Conclusion

L'analyse des parties prenantes montre que la réussite du projet ne dépend pas uniquement des solutions techniques mises en œuvre. Elle repose également sur une gouvernance efficace et une répartition claire des responsabilités.

La Direction générale devra soutenir la démarche de cybersécurité en validant les investissements et en fixant les orientations stratégiques. La DSI assurera le pilotage opérationnel du projet, tandis que les collaborateurs devront être sensibilisés aux bonnes pratiques afin de limiter les risques d'origine humaine.

Le prestataire Iron4Software représente un point de vigilance particulier. Son intervention sur le développement de la plateforme nécessite une gestion rigoureuse des habilitations, une traçabilité des actions réalisées et un encadrement contractuel précisant les exigences de sécurité attendues.

Enfin, la désignation d'un DPO apparaît comme une mesure prioritaire afin de renforcer la conformité au RGPD et de structurer la gouvernance des données personnelles.

---

4 Mise en place d'une veille cybersécurité

4.1 Contexte

Dans le cadre de son projet de transformation numérique, BioMarket doit être capable d'identifier rapidement les nouvelles cybermenaces susceptibles d'affecter son système d'information.

La mise en œuvre d'une veille cybersécurité permettra d'anticiper les risques, de suivre les vulnérabilités publiées, de rester conforme aux évolutions réglementaires et d'adapter les mesures de protection en fonction des nouvelles menaces.

Cette démarche s'inscrit pleinement dans le processus d'amélioration continue recommandé par la norme ISO/IEC 27001.

4.2 Objectifs de la veille

La veille poursuivra plusieurs objectifs :

- détecter les nouvelles vulnérabilités ;
- identifier les campagnes de phishing et de ransomware ;
- suivre les recommandations des organismes officiels ;
- anticiper les impacts sur la plateforme e-commerce ;
- améliorer les procédures internes.

4.3 Sources retenues

Source	**Domaine**	**Fréquence**	**Justification**
ANSSI	Alertes nationales	Quotidienne	Recommandations françaises
CERT-FR	Vulnérabilités	Quotidienne	Alertes de sécurité
CVE	Vulnérabilités	Quotidienne	Référentiel mondial
CVSS	Criticité	À chaque nouvelle CVE	Priorisation des correctifs
OWASP	Applications Web	Hebdomadaire	Sécurisation de la plateforme e-commerce
MITRE ATT&CK	Techniques d'attaque	Hebdomadaire	Compréhension des modes opératoires
CISA	Alertes internationales	Hebdomadaire	Veille mondiale
ENISA	Bonnes pratiques européennes	Mensuelle	Conformité et recommandations

Source	Domaine	Fréquence	Justification
CNIL	Réglementation	Mensuelle	Protection des données personnelles
NIST	Référentiels techniques	Mensuelle	Guides de sécurité

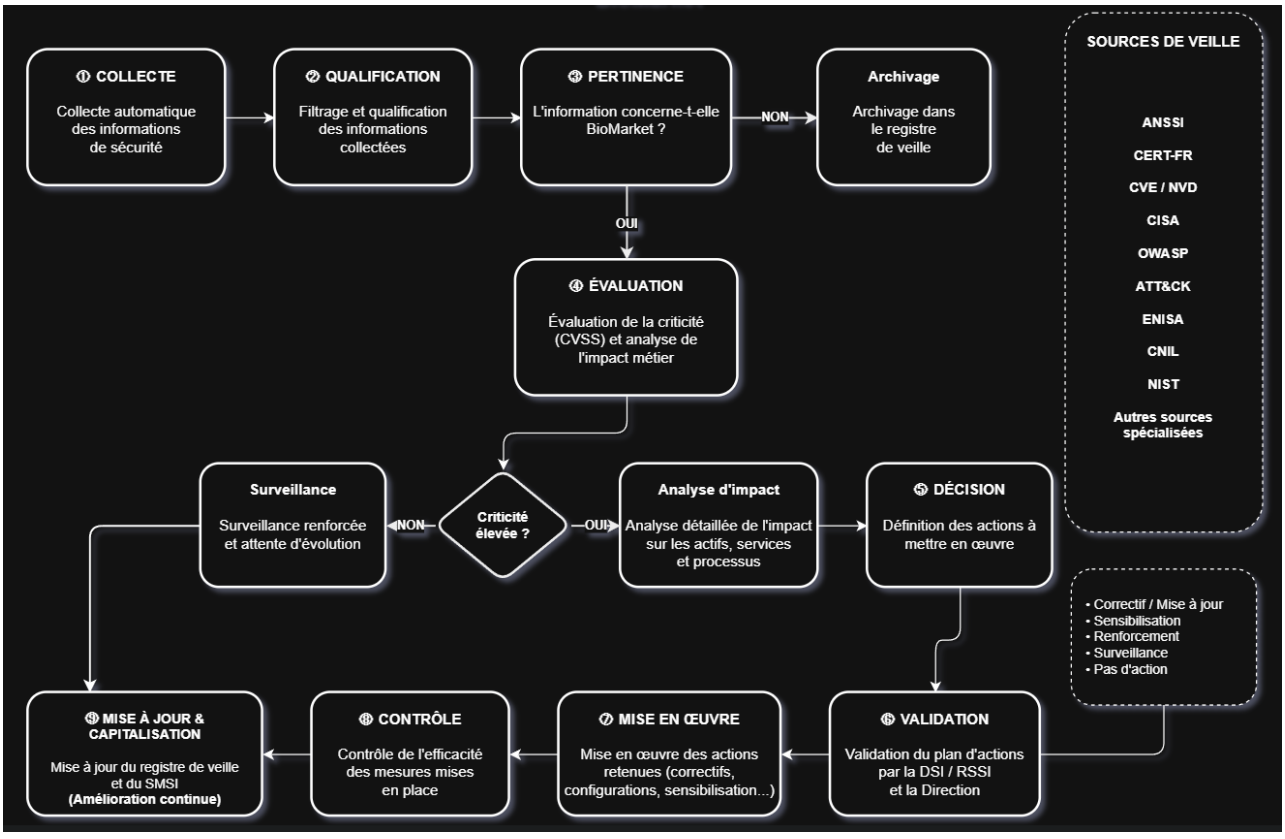
4.4 Procédure de veille

La procédure de veille cybersécurité repose sur une démarche structurée permettant de collecter, analyser et traiter les informations susceptibles d'avoir un impact sur BioMarket.

La veille est réalisée à partir des sources identifiées précédemment. Les informations collectées sont analysées afin d'évaluer leur pertinence et leur impact potentiel sur le système d'information et les activités de BioMarket.

Lorsqu'une information présente un risque pour l'entreprise, une action adaptée est définie : mise à jour d'un système, renforcement d'une mesure de sécurité, sensibilisation des utilisateurs ou évolution d'une procédure. L'information et l'action associée sont ensuite enregistrées dans le tableau de suivi de veille.

Le suivi des actions permet de vérifier leur réalisation et leur efficacité. Cette démarche contribue à l'amélioration continue du dispositif de sécurité et pourra être intégrée au fonctionnement du futur SMSI.



4.5 Tableau de suivi de veille

Date	Source	Sujet	Criticité	Impact BioMarket	Action	Responsable	Statut
15/07/2026	CERT-FR	Vulnérabilité VPN	Critique	Fort	Correctif immédiat	DSI	Clos
18/07/2026	ANSSI	Nouvelle campagne de phishing	Élevée	Moyen	Sensibilisation	DSI	En cours
22/07/2026	CVE	Faille Apache	Critique	Fort	Mise à jour serveur	Administrateur système	Ouvert

---

4.6 Outils de veille

Les outils suivants sont proposés:

Outil	Utilité
Feedly	Agrégation de flux RSS
Google Alerts	Alertes sur des mots-clés
MISP	Partage d'indicateurs de compromission (IOC)
Microsoft Defender Threat Intelligence (ou équivalent)	Renseignement sur les menaces

---

4.7 Conclusion

La veille cybersécurité constitue un élément indispensable de la gouvernance de la sécurité de BioMarket. Dans un contexte de transformation numérique, elle permettra d'anticiper les nouvelles menaces et d'adapter rapidement les mesures de protection.

Le choix de sources reconnues (ANSSI, CERT-FR, CVE, OWASP, MITRE ATT&CK) garantit la fiabilité des informations collectées. La formalisation d'une procédure de veille et d'un registre de suivi assurera la traçabilité des actions menées et facilitera l'amélioration continue du futur SMSI.

5 Analyse OSINT

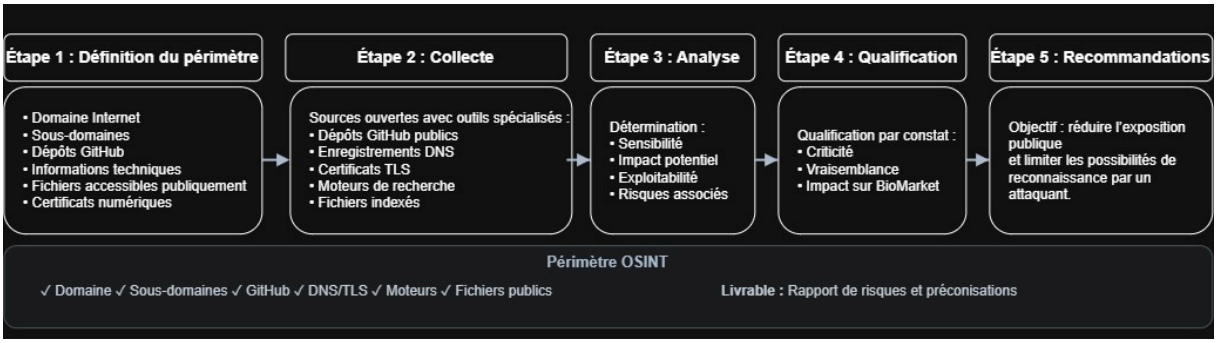
5.1 Objectif

Une analyse OSINT a été réalisée afin d'évaluer l'exposition numérique publique de l'entreprise. Cette démarche vise à identifier les informations accessibles librement sur Internet pouvant être exploitées par un attaquant pour préparer une cyberattaque.

L'objectif n'est pas de réaliser une intrusion, mais d'identifier les éléments publiquement accessibles susceptibles d'augmenter la surface d'attaque de BioMarket.

5.2 Méthodologie

L'analyse OSINT s'est déroulée selon les étapes suivantes.



5.3 Outils utilisés

Outil	**Objectif**
Google Dorks	Recherche de fichiers et informations indexés
GitHub	Recherche de dépôts publics
crt.sh	Recherche des certificats TLS
Shodan	Identification des services exposés
DNS Lookup	Recherche des sous-domaines
VirusTotal	Vérification de la réputation de domaines
Have I Been Pwned	Recherche de fuites d'identifiants

5.4 État des lieux de l'exposition numérique

L'analyse OSINT réalisée sur BioMarket a permis d'identifier plusieurs points de vigilance concernant son exposition numérique publique.

Les principaux constats sont les suivants :

Constat	Risque	Niveau
Dépôts GitHub contenant des identifiants en clair	Compromission des comptes et accès non autorisés	Critique
Sous-domaines accessibles sans protection	Reconnaissance de l'infrastructure	Élevé
Fichiers CSV accessibles sans authentification	Divulgation de données sensibles	Critique
Certificats TLS révélant des sous-domaines internes	Cartographie facilitée du SI	Moyen

L'analyse OSINT a permis d'identifier plusieurs sous-domaines associés à BioMarket, tels que `test.biomarket.fr`, ou `admin.biomarket.fr`. Ces sous-domaines révèlent l'existence d'environnements techniques distincts et fournissent des informations sur l'architecture du système d'information. Si ces environnements sont accessibles publiquement ou insuffisamment protégés, ils peuvent devenir des points d'entrée privilégiés pour un attaquant. Les environnements de test étant souvent moins sécurisés que la production, leur exposition augmente significativement la surface d'attaque de l'entreprise.

5.5 Analyse des résultats

Les résultats mettent en évidence une exposition numérique supérieure à celle attendue pour une entreprise développant une plateforme e-commerce.
Les dépôts GitHub contenant des identifiants représentent le risque le plus important, car ils peuvent conduire à une compromission directe des systèmes d'information.
Les sous-domaines non protégés facilitent la phase de reconnaissance des attaquants en révélant une partie de l'architecture technique.
Enfin, les fichiers CSV accessibles sans authentification constituent une vulnérabilité majeure susceptible d'entraîner une fuite de données.

5.6 Recommandations

Afin de réduire l'exposition numérique de BioMarket, les recommandations suivantes sont proposées :

- supprimer immédiatement les identifiants présents dans les dépôts GitHub ;
- mettre en place une revue régulière des dépôts de code afin d'éviter toute nouvelle exposition d'informations sensibles ;
- sécuriser les sous-domaines inutilisés ou non protégés en les supprimant ou en appliquant une configuration adaptée ;
- limiter l'accès aux fichiers sensibles en imposant une authentification et des contrôles d'autorisation ;
- réaliser des analyses OSINT périodiques afin de détecter rapidement toute nouvelle exposition publique.

5.7 Conclusion

L'analyse OSINT met en évidence que plusieurs informations sensibles sont accessibles publiquement sans qu'une compromission du système d'information soit nécessaire. Cette situation augmente la surface d'attaque de BioMarket et facilite les actions de reconnaissance réalisées par un cyberattaquant.

Les vulnérabilités observées concernent principalement la gestion des dépôts de code, l'exposition de ressources Web et la publication involontaire de données sensibles.

La mise en œuvre des recommandations proposées permettra de réduire significativement cette exposition numérique et de renforcer la posture de sécurité de BioMarket avant la mise en production de la plateforme e-commerce.

6 Identifier les besoins spécifiques de BioMarket en matière de sécurité

6.1 Objectif

Avant de définir les mesures de protection à mettre en œuvre, il est nécessaire d'identifier les besoins spécifiques de BioMarket en matière de sécurité de l'information. Cette étape consiste à déterminer les exigences de sécurité des actifs de l'entreprise afin de garantir leur protection contre les menaces susceptibles d'affecter le système d'information.

Les besoins de sécurité sont évalués selon les critères **DICP** : **Disponibilité, Intégrité, Confidentialité et Preuve (Traçabilité)**. Ces critères permettent d'adapter le niveau de protection à chaque actif en fonction de son importance pour l'entreprise.

Cette analyse constitue une étape préalable indispensable à l'analyse des risques qui sera réalisée ultérieurement.

6.2 Contexte de BioMarket

BioMarket est une entreprise spécialisée dans la distribution de produits biologiques qui souhaite développer une plateforme de vente en ligne afin d'élargir son activité.

Ce projet implique le traitement de nombreuses informations sensibles telles que :

- les données personnelles des clients ;
- les commandes en ligne ;
- les informations relatives aux fournisseurs ;
- les données financières ;
- les informations internes de l'entreprise.

Le développement de cette plateforme est confié au prestataire Iron4Software, ce qui introduit également des enjeux liés à la sécurité des développements et à la gestion des accès des prestataires.

L'identification des besoins de sécurité permettra de garantir la protection de ces informations tout au long de leur cycle de vie.

6.3 Les besoins de sécurité selon le modèle DICP

La sécurité d'un système d'information repose sur quatre besoins fondamentaux : **Disponibilité, Intégrité, Confidentialité et Preuve (Traçabilité)**. Chaque actif doit être évalué selon ces critères afin de déterminer le niveau de protection attendu.

Confidentialité

La confidentialité garantit que seules les personnes autorisées peuvent accéder aux informations.

Pour BioMarket, cette exigence concerne principalement :

- les données personnelles des clients ;
- les informations relatives aux salariés ;

- les contrats fournisseurs ;
- les informations commerciales ;
- les identifiants et mots de passe.

Une atteinte à la confidentialité pourrait entraîner une violation du RGPD, une perte de confiance des clients ainsi qu'un préjudice financier et réputationnel.

Intégrité

L'intégrité garantit que les informations restent exactes, complètes et ne sont modifiées que par des personnes autorisées.

Pour BioMarket, il est indispensable de garantir :

- l'exactitude des commandes ;
- l'intégrité des prix affichés sur le site ;
- la fiabilité des stocks ;
- la cohérence des données comptables.

Une modification frauduleuse ou accidentelle de ces informations pourrait avoir un impact direct sur le fonctionnement de l'entreprise.

Disponibilité

La disponibilité garantit que les informations et les services restent accessibles lorsque les utilisateurs en ont besoin.

Pour BioMarket, ce besoin est particulièrement important puisque la plateforme e-commerce constitue le principal canal de vente en ligne.

Une indisponibilité du site pourrait empêcher les clients de passer commande, provoquer une perte de chiffre d'affaires et dégrader l'image de l'entreprise.

La disponibilité devra notamment être assurée grâce aux sauvegardes, à la redondance des services et à un plan de continuité d'activité (PCA).

Preuve (Traçabilité)

Le quatrième critère, appelé **Preuve** ou **Traçabilité**, permet d'assurer l'imputabilité des actions réalisées sur le système d'information.

Pour BioMarket, il sera nécessaire de conserver des journaux d'événements permettant de :

- tracer les connexions des utilisateurs ;
- enregistrer les actions des administrateurs ;
- conserver les historiques de modification ;
- faciliter les audits et les investigations en cas d'incident.

Cette traçabilité est indispensable pour répondre aux exigences de sécurité et de conformité.

6.4 Identification des besoins spécifiques de BioMarket

À partir de l'analyse du contexte de l'entreprise, plusieurs besoins spécifiques ont été identifiés.

Besoin	**Justification**	**Critère DICP**
Protéger les données personnelles des clients	Respect du RGPD et protection de la vie privée	Confidentialité
Garantir l'intégrité des commandes	Éviter les erreurs ou les modifications frauduleuses	Intégrité
Assurer la disponibilité de la plateforme e-commerce	Garantir la continuité des ventes	Disponibilité
Sécuriser les accès des administrateurs et du prestataire Iron4Software	Limiter les accès non autorisés	Confidentialité / Preuve
Mettre en place une journalisation des actions	Faciliter les audits et les investigations	Preuve
Sauvegarder les données critiques	Restaurer rapidement les services après un incident	Disponibilité
Sécuriser les développements réalisés par le prestataire	Prévenir l'introduction de vulnérabilités	Intégrité / Confidentialité
Sensibiliser les collaborateurs	Réduire les risques liés aux erreurs humaines	Tous les critères DICP

6.5 Les mécanismes de sécurité associés

Un besoin de sécurité est satisfait grâce à un ou plusieurs **mécanismes de sécurité** et que ces mécanismes sont complémentaires. Cette approche s'inscrit dans le principe de **défense en profondeur**, selon lequel plusieurs couches de protection doivent être mises en œuvre afin de réduire le risque global.

Pour répondre aux besoins identifiés, BioMarket pourra notamment mettre en œuvre les mécanismes suivants :

Besoin	**Mécanismes de sécurité**
Confidentialité	Contrôle d'accès, authentification multifacteur (MFA), chiffrement
Intégrité	Contrôle des modifications, revues de code, antivirus/EDR
Disponibilité	Sauvegardes, redondance, PCA/PRA
Preuve	Journalisation, supervision (SIEM), conservation des logs

Besoin	Mécanismes de sécurité
Protection du réseau	Pare-feu, segmentation réseau, VPN
Sensibilisation	Formations régulières à la cybersécurité

Cette combinaison de mesures permet d'assurer une protection cohérente des actifs critiques de BioMarket.

6.6 Conclusion

L'identification des besoins de sécurité montre que les principaux enjeux de BioMarket concernent la protection des données personnelles, la disponibilité de la plateforme e-commerce, l'intégrité des informations commerciales et la traçabilité des actions réalisées sur le système d'information.

L'utilisation du modèle **DICP**, permet de structurer cette analyse et de définir les exigences de sécurité adaptées aux actifs de l'entreprise. Ces besoins serviront de base à l'analyse des risques et au choix des mesures de sécurité qui seront développés dans les chapitres suivants.

7 Cartographie de l'architecture technique actuelle

7.1 Objectif

La cartographie de l'architecture technique a pour objectif de représenter le système d'information actuel de BioMarket afin d'identifier ses principaux composants, leur organisation, leurs dépendances ainsi que les flux de communication entre les différents acteurs internes et externes.
Cette représentation permet notamment d'identifier les actifs techniques de l'entreprise, de comprendre les chemins de communication entre les différentes zones du système d'information et de préparer les étapes suivantes du projet, notamment l'analyse des risques et la définition des mesures de sécurité.

La cartographie constitue ainsi un état des lieux de l'architecture existante. Elle ne représente pas les évolutions ou mesures de sécurité qui pourront être proposées ultérieurement dans le cadre de l'architecture cible.

7.2 Périmètre de la cartographie

La cartographie couvre l'infrastructure actuellement exploitée par BioMarket et les principaux composants externes avec lesquels le système d'information échange.

Elle comprend :

- le site principal de **Tourcoing** ;
- les réseaux locaux et leurs différents VLAN ;
- le pare-feu central **FortiGate 100F** ;
- le commutateur cœur **FortiSwitch 148F** ;
- les serveurs d'infrastructure ;
- les serveurs applicatifs et de données ;
- les postes utilisateurs ;
- les utilisateurs nomades ;
- les magasins distants interconnectés par MPLS ;
- le stockage Cloud externalisé ;
- la plateforme e-commerce hébergée sur une infrastructure PaaS exploitée par **Iron4Software**;
- les principaux flux réseau et applicatifs associés.

La plateforme e-commerce est considérée comme un composant du SI de BioMarket, même si son infrastructure PaaS et ses composants internes sont administrés par le prestataire.

7.3 Description générale de l'architecture

L'architecture technique de BioMarket est organisée autour du site principal de **Tourcoing**, qui centralise les principaux services d'infrastructure, les serveurs métiers et les équipements réseau.

Le périmètre réseau du site est protégé par un **FortiGate 100F**, qui assure notamment la protection périmétrique, le filtrage des communications, le routage inter-VLAN ainsi que la terminaison des connexions VPN SSL.

Le pare-feu est raccordé à un **FortiSwitch 148F**, constituant le cœur de commutation du réseau local. Le réseau de Tourcoing est organisé en plusieurs VLAN permettant de séparer les différentes fonctions du système d'information.

VLAN 11 – RH & Direction
Associé au réseau 192.168.11.0/24, il regroupe les postes de la Direction et des Ressources Humaines.

VLAN 12 – Informatique
Associé au réseau 192.168.12.0/24, il regroupe les postes des collaborateurs de l'équipe informatique.

VLAN 13 – Autres utilisateurs
Associé au réseau 192.168.13.0/24, il regroupe les autres postes utilisateurs du site de Tourcoing.

Les postes utilisent un adressage IP dynamique fourni par le service DHCP et s'authentifient auprès de l'Active Directory centralisé.

VLAN 20 – Serveurs et données

Le VLAN 20, associé au réseau **192.168.20.0/24**, regroupe les principaux serveurs applicatifs et de données.

Il comprend notamment :

- le serveur de fichiers **SRV-FS01**, à l'adresse **192.168.20.15**, fournissant les partages SMB ;
- le serveur de base de données **SRV-DB01**, à l'adresse **192.168.20.20**, hébergeant PostgreSQL ;
- le serveur applicatif interne, à l'adresse **192.168.20.30**, utilisé pour les applications métiers.

VLAN 50 – Infrastructure et services cœur

Le VLAN 50, associé au réseau **192.168.50.0/24**, regroupe les principaux services d'infrastructure.

Il comprend notamment :

- **DC01**, serveur Active Directory à l'adresse **192.168.50.10** ;
- les services **AD DS** ;
- **DNS interne** ;
- **DHCP**.

L'Active Directory centralise l'authentification des utilisateurs, la gestion des groupes, les habilitations et l'application des stratégies de sécurité via les GPO.

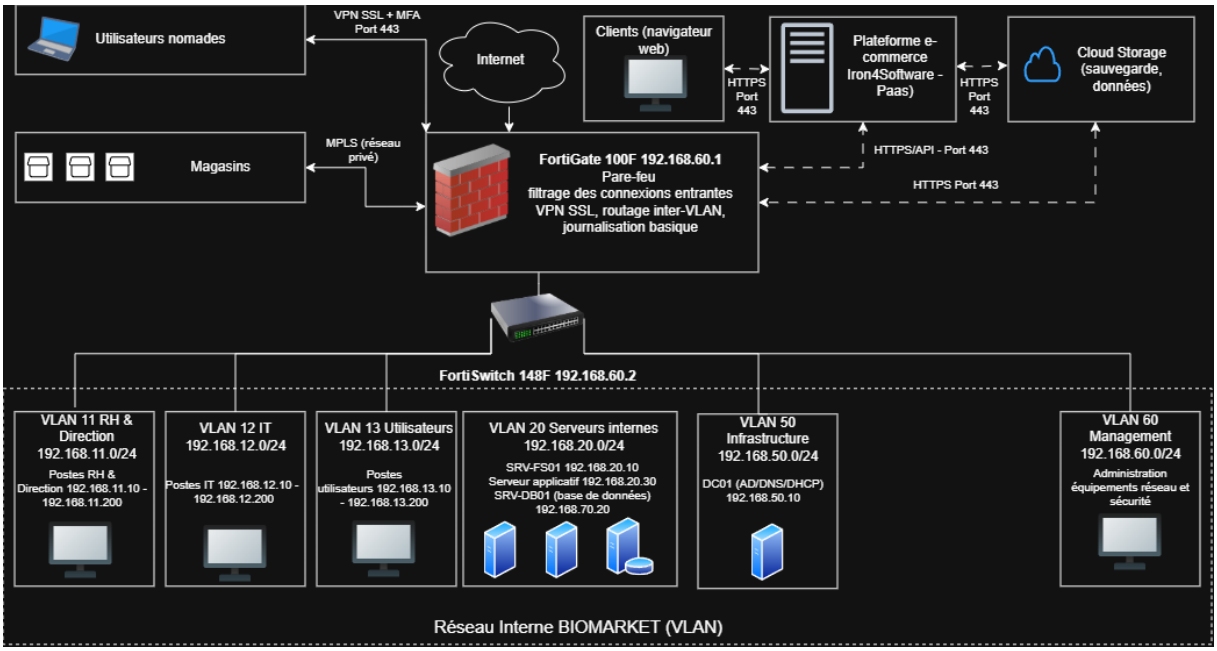
VLAN 60 – Management réseau

Le VLAN 60, associé au réseau **192.168.60.0/24**, est dédié à l'administration des équipements réseau et des interfaces de management.

Il comprend notamment :

- le **FortiGate 100F**, à l'adresse **192.168.60.1** ;
- le **FortiSwitch 148F**, à l'adresse **192.168.60.2**.

Les connexions d'administration sont réalisées via des protocoles sécurisés tels que **HTTPS et SSH**, selon les équipements concernés.



7.4 Connexions externes et accès distants

Les utilisateurs nomades accèdent au système d'information au moyen d'un VPN SSL terminé sur le FortiGate 100F.

La connexion utilise le port 443 et repose sur une authentification par certificat numérique. Les comptes disposant de privilèges élevés bénéficient en complément d'une authentification multifacteur (MFA).

Les magasins distants sont interconnectés au site de Tourcoing par un réseau MPLS privé fourni par un opérateur télécom. Cette liaison permet aux terminaux de caisse et aux équipements des magasins d'accéder aux ressources centralisées nécessaires à leur activité.

Les magasins ne disposent pas d'une sortie Internet directe représentée dans l'architecture actuelle ; leurs échanges avec les ressources du SI central passent par l'interconnexion WAN privée.

7.5 Plateforme e-commerce et services Cloud

La plateforme e-commerce de BioMarket est développée et hébergée par Iron4Software sur une infrastructure PaaS.

Les clients accèdent à cette plateforme directement depuis Internet au moyen du protocole HTTPS sur le port 443.

La plateforme communique avec le système d'information interne de BioMarket au moyen d'API REST sécurisées par HTTPS. Ces échanges permettent notamment de synchroniser les commandes, les stocks et les informations nécessaires au fonctionnement de l'activité e-commerce.

BioMarket utilise également un stockage Cloud externalisé. Les échanges avec ce stockage sont réalisés via HTTPS sur le port 443.

Les données hébergées dans le Cloud bénéficient d'un chiffrement côté fournisseur. À l'inverse, certaines données conservées localement sur le serveur de fichiers et la base PostgreSQL sont actuellement stockées sans chiffrement au repos.

7.6 Description des principaux flux

L'analyse de la cartographie permet d'identifier les principaux flux suivants :

Flux	**Source**	**Destination**	**Protocole / port**
Accès e-commerce	Clients Internet	Plateforme PaaS	HTTPS / 443
API e-commerce	Plateforme PaaS	Applications BioMarket	HTTPS / 443
Accès nomade	Utilisateurs distants	FortiGate	VPN SSL / 443
Échanges de données Cloud	PaaS / plateforme e-commerce	Stockage Cloud	HTTPS / 443
Accès au stockage Cloud	SI BioMarket	Stockage Cloud	HTTPS / 443
Authentification	Postes utilisateurs	DC01	Kerberos / 88, LDAP / 389
DNS	Postes / serveurs	DNS interne	DNS / 53
DHCP	Postes	Serveur DHCP	UDP / 67-68
Partages fichiers	Postes utilisateurs	SRV-FS01	SMB / 445
Applications internes	Utilisateurs	Serveur applicatif	HTTP/HTTPS / 80-443
Accès BDD	Application	SRV-DB01	PostgreSQL / 5432
Administration	VLAN 60	Interfaces de management des équipements réseau	HTTPS / 443, SSH / 22
Magasins	Réseaux magasins	Site de Tourcoing	MPLS privé

Cette représentation permet de distinguer les flux Internet, les flux internes, les accès distants par VPN et les échanges intersites via MPLS.

7.7 Inventaire des principaux composants

L'inventaire technique est présenté ci-dessous afin de faciliter la mise en correspondance entre les actifs identifiés dans la cartographie et l'analyse des risques.

Composant	Fonction	Localisation	Adresse IP	Technologie
FortiGate 100F	Pare-feu, VPN, routage inter-VLAN	Tourcoing	192.168.60.1	FortiOS
FortiSwitch 148F	Commutation cœur	Tourcoing	192.168.60.2	FortiSwitch
DC01	Active Directory	Tourcoing	192.168.50.10	Windows Server 2022
DNS/DHCP	Services réseau	Tourcoing	192.168.50.10	Windows Server 2022
SRV-FS01	Serveur de fichiers	Tourcoing	192.168.20.15	Windows Server 2022
SRV-DB01	Base de données	Tourcoing	192.168.20.20	PostgreSQL / Ubuntu
Serveur applicatif	Applications métiers	Tourcoing	192.168.20.30	Application interne
Postes utilisateurs	Poste de travail	Tourcoing	VLAN 11 (192.168.11.0/24) VLAN 12(192.168.12.0/24) VLAN13(192.168.13.0/24)	Windows 11 Pro
VPN SSL	Accès distant	FortiGate	—	Fortinet SSL VPN
Réseau MPLS	Interconnexion magasins	WAN	—	MPLS opérateur
Plateforme PaaS	E-commerce	Externe	—	PaaS / Iron4Software
Stockage Cloud	Stockage externalisé	Externe	—	Service Cloud

7.8 Analyse de l'architecture actuelle

L'architecture actuelle présente plusieurs éléments favorables.

La centralisation des services d'infrastructure à Tourcoing permet de conserver une administration centralisée des identités, des postes et des ressources. La segmentation en VLAN permet également de distinguer les postes utilisateurs, les serveurs, les services d'infrastructure et le management réseau.

Le FortiGate 100F constitue un point central de contrôle des communications entre les différentes zones du réseau. Les accès distants sont protégés par un VPN SSL et les comptes à privilèges bénéficient d'une authentification multifacteur.

L'interconnexion des magasins par MPLS permet par ailleurs de conserver une connectivité privée entre les différents sites et les ressources centralisées.

Cependant, plusieurs points de vigilance apparaissent.

Données locales non chiffrées. Certaines données stockées sur le serveur de fichiers et la base PostgreSQL ne bénéficient actuellement pas d'un chiffrement au repos. Cela constitue un risque en cas de compromission ou de vol du support de stockage.

Centralisation des services. L'architecture repose fortement sur les services centralisés de Tourcoing, notamment l'Active Directory, les applications métiers et la base de données. Une indisponibilité du site peut donc affecter plusieurs activités simultanément.

Dépendance aux prestataires externes. La plateforme e-commerce dépend d'Iron4Software et le stockage Cloud dépend d'un fournisseur externe. Ces dépendances doivent être prises en compte dans l'analyse des risques et dans la gestion des fournisseurs.

Exposition de la plateforme e-commerce. La plateforme PaaS est directement accessible depuis Internet. Les interfaces API permettant les échanges avec le SI interne constituent donc des flux sensibles qui devront être particulièrement contrôlés.

Traçabilité. La cartographie fait apparaître plusieurs équipements et services critiques, mais la centralisation des journaux de sécurité n'est pas actuellement représentée. La capacité à corréler les événements issus du FortiGate, des serveurs et de l'Active Directory devra donc être évaluée.

7.9 Conclusion

La cartographie met en évidence une architecture centralisée autour du site de Tourcoing, composée d'un FortiGate 100F, d'un FortiSwitch 148F, de plusieurs VLAN et de services d'infrastructure et métiers centralisés.

Les magasins distants sont raccordés au site principal par un réseau MPLS privé, tandis que les collaborateurs nomades utilisent un VPN SSL pour accéder aux ressources internes. La plateforme e-commerce et le stockage Cloud constituent quant à eux des services externalisés, intégrés au système d'information de BioMarket et faisant l'objet d'échanges avec les infrastructures internes.

L'architecture actuelle présente donc plusieurs mécanismes de sécurité déjà en place, notamment le filtrage réseau, la segmentation par VLAN, le VPN SSL, l'authentification par certificat et le MFA pour les comptes à privilèges.

Elle présente néanmoins plusieurs points de vigilance concernant notamment le chiffrement des données locales, la dépendance aux prestataires externes, les échanges avec la plateforme PaaS et la centralisation de la journalisation.

Ces éléments seront repris dans les chapitres suivants afin d'évaluer leur niveau de risque et de définir les mesures de sécurité appropriées.